

รายงานโครงงาน

WordPress บน VPS

จัดทำโดย

จิรวัฒน์ ถนอมมิตร	67160062
ณรงค์กร กล่อมแก้ว	67160088
ดนุพร แสงทอง	67160093
นภสินธุ์ ประถมวงษ์	67160096
จิรเมธ วงศ์เมืองแก่น	67160252
ณัฐวุฒิ พูลสวัสดิ์	67160259
สราวุธ ยุติธรรม	67160276
เหวินป๋อ เฉิน	67160278

เสนอ

เสนอ ผศ.ภูสิต กุลเกษม

รายงานนี้เป็นส่วนหนึ่งของรายวิชา

รายวิชา 88633065-65 Computer Networks

ภาคเรียนที่ 1 ปีการศึกษา 2569

คณะวิทยาการสารสนเทศ สาขาวิทยาการคอมพิวเตอร์

มหาวิทยาลัยบูรพา

คำนำ

รายงานฉบับนี้เป็นส่วนหนึ่งของรายวิชา 88633065-65 Computer Networks ภาคเรียนที่ 1 ปีการศึกษา 2569 จัดทำขึ้นเพื่อบันทึกการติดตั้งเว็บไซต์ WordPress แนะนำหลักสูตรวิทยาการคอมพิวเตอร์บนเครื่องเซิร์ฟเวอร์เสมือน (VPS) ของ Microsoft Azure ซึ่งคณะผู้จัดทำลงมือทำเองทั้งระบบ
เนื้อหาครอบคลุมการเปิดใช้งาน HTTPS การตั้งค่า SSH ให้ปลอดภัย
การตั้งไฟร์วอลล์ให้เข้าถึงได้เฉพาะจากประเทศไทยการติดตั้ง reverse proxy และระบบวิเคราะห์ล็อกด้วยปัญญาประดิษฐ์
รวมถึงปัญหาที่พบระหว่างทำและวิธีแก้ไข

คณะผู้จัดทำขอขอบพระคุณ ผศ.ภูสิต กุลเกษม ที่ให้คำแนะนำตลอดการทำโครงงานหวังว่ารายงานฉบับนี้จะเป็นประโยชน์แก่ผู้ที่สนใจหากมีข้อผิดพลาดประการใดคณะผู้จัดทำขออภัยมา ณ ที่นี้

คณะผู้จัดทำ

สารบัญ

1. บทนำและสรุปผล 5
1.1 วัตถุประสงค์ 5
1.2 สรุปผลตามโจทย์ 5
2. สถาปัตยกรรมระบบ 6
2.1 ข้อมูลเซิร์ฟเวอร์ 6
2.2 ตาราง version ซอฟต์แวร์ 6
2.3 แผนภาพสถาปัตยกรรม 7
3. ด่านที่ 1 — เซิร์ฟเวอร์ · HTTPS · SSH ปลอดภัย 9
3.1 สร้างเซิร์ฟเวอร์และเตรียมระบบ 9
3.2 SSH: ปิด root · ปิดรหัสผ่าน · ใช้ public key เท่านั้น 9
3.3 ติดตั้ง Nginx + PHP-FPM + MySQL 8 + WordPress 11
3.4 DuckDNS และ HTTPS 11
4. ด่านที่ 2 — Firewall บล็อกการเชื่อมต่อจากต่างประเทศ 13
4.1 หลักการ 13
4.2 กฎ iptables และผลการทำงานจริง 13
4.3 ผลการทดสอบ 14
5. ด่านที่ 3 — เว็บไซต์แนะนำหลักสูตรวิทยาการคอมพิวเตอร์ 16
5.1 โครงสร้างเว็บไซต์ 16
5.2 Theme และ Plugin 17
5.3 การเพิ่มความปลอดภัยของ WordPress 18
6. Stage 2 — ยกระดับความปลอดภัยและประสิทธิภาพ 19
6.1 Reverse Proxy 19
6.2 AI วิเคราะห์ Log และ Security Dashboard 21
6.3 Cloudflare 24
7. การตรวจและเสริมความปลอดภัยหลังติดตั้ง 25
7.1 ผลการตรวจความปลอดภัย 25
7.2 ปิดการสืบชื่อผู้ใช้ให้ครบทุกช่องทาง 26
7.3 Content-Security-Policy แบบ hash 27
7.4 ลดสิทธิ์ผู้ดูแลและการยืนยันตัวตน 2 ขั้นตอน 28

7.5 ตัวกรองรายชื่อ IP ไทย 28
7.6 การรับมือช่องโหว่ฉุกเฉิน PHP2Shell 28
7.7 ระบบแจ้งเตือนทาง Discord 29
7.8 ปัญหาที่พบระหว่างเสริมความปลอดภัย 30
8. ปัญหาที่พบและแนวทางแก้ไข 32
9. สรุปและข้อเสนอแนะ 34
9.1 สรุป 34
9.2 สิ่งที่ได้เรียนรู้ 34
9.3 ข้อเสนอแนะสำหรับการพัฒนาต่อ 34
ภาคผนวก — สคริปต์และไฟล์ในโครงงาน 35

1. บทนำและสรุปผล

1.1 วัตถุประสงค์

ติดตั้งเว็บไซต์ WordPress แนะนำหลักสูตรวิทยาการคอมพิวเตอร์บนเซิร์ฟเวอร์คลาวด์ (VPS) ด้วยตนเองทั้งหมด ตั้งแต่สร้างเครื่อง ตั้งค่าโดเมนและ HTTPS ป้องกัน SSH ทำ firewall ให้เข้าถึงได้เฉพาะจากประเทศไทย จนถึงยกระดับความปลอดภัยและประสิทธิภาพด้วย reverse proxy และระบบ AI วิเคราะห์ log

1.2 สรุปผลตามโจทย์

ตารางที่ 1 สรุปผลการดำเนินงานเทียบกับโจทย์

ส่วน	โจทย์	ผล
ด่าน 1	เข้าเว็บผ่าน https://<ชื่อ>.duckdns.org ที่ชี้มายัง VPS ที่ติดตั้ง WordPress	https://freexduk.duckdns.org (Let's Encrypt, TLS 1.3)
ด่าน 1	SSH: ปิด root login, ปิด password authentication, ใช้ PKI (public key) เท่านั้น	ทดสอบแล้ว root และ password ถูกปฏิเสธ
ด่าน 1	แสดงสถาปัตยกรรมพร้อม version ของ nginx / PHP / WordPress / MySQL	หัวข้อ 2
ด่าน 2	Firewall บล็อกการเชื่อมต่อจากต่างประเทศ (เข้าได้เฉพาะไทย)	iptables + ipset · ทดสอบจาก 40 เซิร์ฟเวอร์ทั่วโลก เข้าไม่ได้ทั้งหมด
ด่าน 3	เว็บ WordPress แนะนำหลักสูตรวิทยาการคอมพิวเตอร์ ให้ดูสวยงาม	หน้าแรก · หลักสูตร · สหกิจศึกษา · รับสมัคร · ติดต่อ
Stage 2	Reverse proxy	TTFB เร็วขึน 35 – 53% · rate limit · micro-cache
Stage 2	AI scan log ตามระยะเวลา → dashboard ตรวจสอบการโจมตี	Claude API วิเคราะห์ทุก 6 ชม. · dashboard มีรหัสผ่าน
Stage 2	Cloudflare cache	ออกแบบไว้แล้ว แต่ DuckDNS ไม่อนุญาตให้ย้าย nameserver

ส่วน	โจทย์	ผล
เพิ่มเติม	ตรวจความปลอดภัยหลังติดตั้งและระบบแจ้งเตือน	ปิดจุดอ่อน 10/11 ข้อ · CSP แบบ hash · แจ้งเตือนทาง Discord (หัวข้อ 7)

2. สถาปัตยกรรมระบบ

2.1 ข้อมูลเซิร์ฟเวอร์

ตารางที่ 2 ข้อมูลเซิร์ฟเวอร์

รายการ	ค่า	หมายเหตุ
ผู้ให้บริการ	Microsoft Azure for Students	เครดิตนักศึกษา $100
Region	Malaysia West (กัวลาลัมเปอร์)	บัญชีนักศึกษาถูก policy จำกัดให้ใช้ได้ 5 region — เลือกที่ใกล้ไทยที่สุด
ขนาดเครื่อง	Standard_B2als_v2 · 2 vCPU · RAM 4 GB · Swap 2 GB	≈ $31/เดือน
ระบบปฏิบัติการ	Ubuntu 24.04.5 LTS (kernel 7.0.0-1017-azure)	–
Public IP / โดเมน	172.197.162.225 / freexduk.duckdns.org	DuckDNS อัปเดต IP อัตโนมัติทุก 5 นาที
ผู้ดูแล	user sysadmin (ไม่ใช่ root) · SSH key เท่านั้น	สมาชิกมีบัญชี WordPress แยกคนละบัญชี

2.2 ตาราง version ซอฟต์แวร์

ตารางที่ 3 version ซอฟต์แวร์และคำสั่งที่ใช้ตรวจ (22 ต.ค. 2569)

ชั้น	ซอฟต์แวร์	version	คำสั่ง
OS	Ubuntu	24.04.5 LTS	lsb_release -a
Web server / Reverse proxy	Nginx	1.24.0	nginx -v
Runtime	PHP-FPM	8.3.6	php -v
Database	MySQL	8.0.46	mysql --version
CMS	WordPress	7.1.3	wp core version
Theme	Kadence	1.5.2	wp theme get kadence
TLS	OpenSSL	3.0.13	openssl version
ใบรับรอง	acme.sh > Let's Encrypt	v3.1.7	acme.sh --version
Container	Docker	29.1.3	docker --version

```
sysadmin@wp-vps:~$ lsb_release -d; nginx -v; php -v | head -1; mysql --version; echo -n "WordPress "; (cd /var/www/freex
duk && sudo -u www-data wp core version); openssl version
No LSB modules are available.
Description:    Ubuntu 24.04.5 LTS
nginx version: nginx/1.24.0 (Ubuntu)
PHP 8.3.6 (cli) (built: Oct 19 2026 15:16:58) (NTS)
mysql  Ver 8.0.46-0ubuntu0.24.04.4 for Linux on x86_64 ((Ubuntu))
WordPress 7.1.3
OpenSSL 3.0.13 30 Jan 2024 (Library: OpenSSL 3.0.13 30 Jan 2024)
```

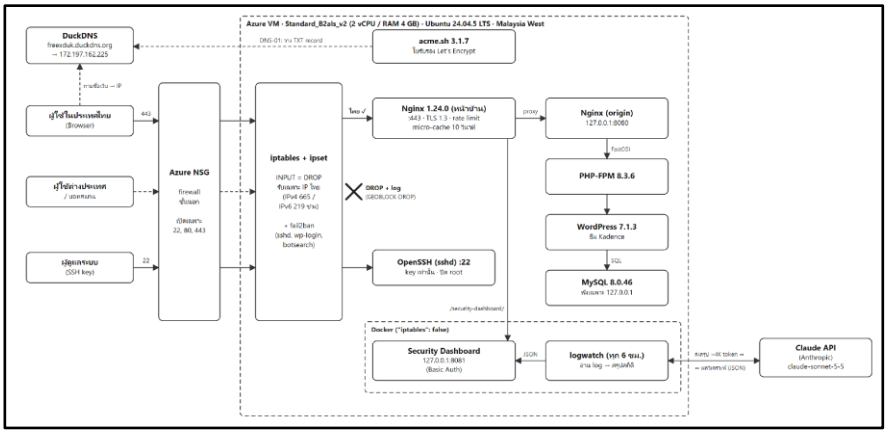
ภาพที่ 1 ผลคำสั่งตรวจ version บนเซิร์ฟเวอร์

2.3 แผนภาพสถาปัตยกรรม

เส้นทางของ request ตั้งแต่ผู้ใช้จนถึงฐานข้อมูล (หลังทำ Stage 2):

ตารางที่ 4 ชั้นของระบบตามลำดับการเดินทางของข้อมูล

ลำดับ	ชั้น	หน้าที่
1	ผู้ใช้ (browser)	พิมพ์ https://freexduk.duckdns.org
2	DuckDNS	แปลงชื่อเป็น IP 172.197.162.225 · ใช้วาง TXT record ตอนขอใบรับรอง (DNS-01)
3	Azure NSG	firewall ระดับคลาวด์ เปิดเฉพาะ port 22, 80, 443
4	iptables + ipset + fail2ban	รับ 22/80/443 เฉพาะ IP ประเทศไทย · แบน IP ที่พยายามเดารหัส/สแกน
5	Nginx หน้าบ้าน (reverse proxy :443)	ถอดรหัส TLS · rate limit · micro-cache · ส่งต่อ IP จริง
6a	Nginx origin (127.0.0.1:8080) > PHP-FPM	รัน WordPress (+ Cache Enabler)
6b	Security Dashboard (127.0.0.1:8081, container)	แสดงผลวิเคราะห์ log · ป้องกันด้วยรหัสผ่าน
7	MySQL 8	ฟังเฉพาะ 127.0.0.1 · user ฐานข้อมูลแยกสำหรับ WordPress
8	logwatch (container, ทุก 6 ชม.)	สรุป log > Claude API วิเคราะห์ > JSON ให้ dashboard



ภาพที่ 2 แผนภาพสถาปัตยกรรม

3. ด่านที่ 1 — เซิร์ฟเวอร์ · HTTPS · SSH ปลอดภัย

3.1 สร้างเซิร์ฟเวอร์และเตรียมระบบ

1. สร้าง VM บน Azure (Ubuntu 24.04 LTS) ใส่ SSH public key ตั้งแต่ตอนสร้าง และเปิด Boot diagnostics ไว้ใช้ Serial Console กู้เครื่อง
2. อัปเดตระบบ (apt full-upgrade) แล้ว reboot เข้า kernel ใหม่
3. สร้าง swap 2 GB (/swapfile, swappiness = 10) กัน MySQL ถูกระบบปิดเมื่อ RAM เต็ม

3.2 SSH: ปิด root · ปิดรหัสผ่าน · ใช้ public key เท่านั้น

ตั้งค่าใน /etc/ssh/sshd_config และไฟล์ /etc/ssh/sshd_config.d/00-hardening.conf (ใช้ชื่อขึ้นต้น 00- เพราะ sshd ใช้ค่าที่อ่านเจอก่อน และไฟล์ของ Azure ชื่อ 50-cloudimg-settings.conf จะถูกอ่านก่อนไฟล์ 99-...)

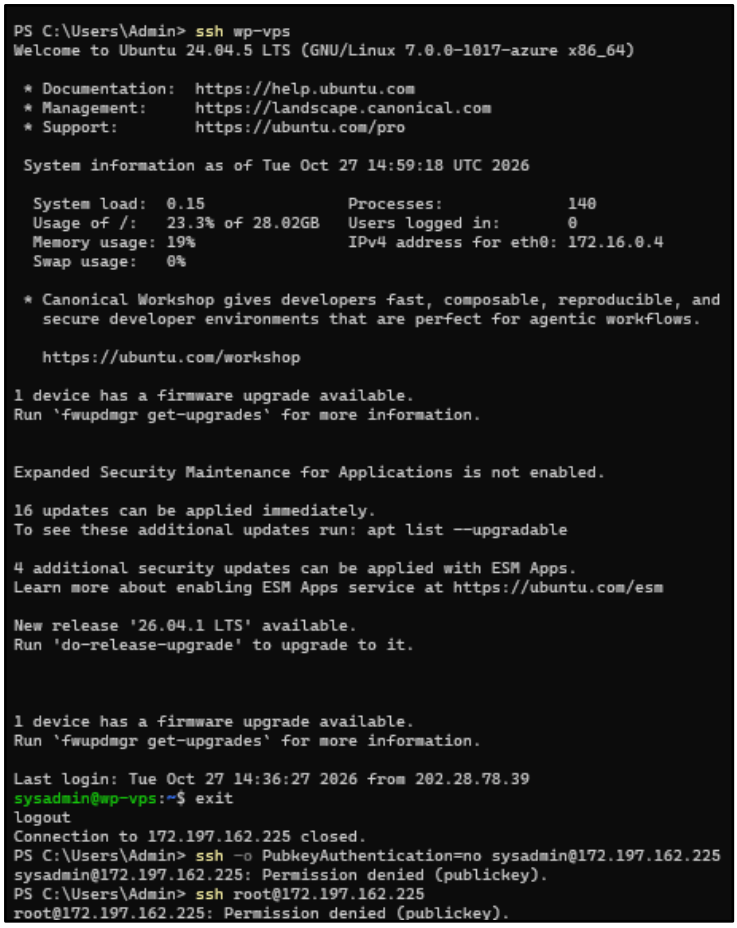
```
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
AuthenticationMethods publickey
AllowUsers sysadmin
MaxAuthTries 3
```

ค่าที่ sshd ใช้งานจริง:

```
$ sudo sshd -T | grep -E 'permitroot|password|pubkey'
permitrootlogin no
pubkeyauthentication yes
passwordauthentication no
permitemptypasswords no
```

ตารางที่ 5 ผลทดสอบ SSH

การทดสอบ	คำสั่ง	ผล
เข้าด้วย key	ssh wp-vps	เข้าได้
เข้าด้วยรหัสผ่าน	ssh -o PubkeyAuthentication=no sysadmin@172.197.162.225	Permission denied (publickey)
เข้าด้วย root	ssh root@172.197.162.225	Permission denied — log: User root not allowed



ภาพที่ 3 ทดสอบ SSH ทั้ง 3 แบบใน PowerShell

3.3 ติดตั้ง Nginx + PHP-FPM + MySQL 8 + WordPress

- ซ่อน version: server_tokens off (Nginx) และ expose_php = Off (PHP)
- MySQL: รัน mysql_secure_installation · root ใช้ auth_socket · ฟังเฉพาะ 127.0.0.1 · สร้าง database wordpress และ user wpuser ที่มีสิทธิ์เฉพาะ database ของตัวเอง (least privilege)
- WordPress ติดตั้งที่ /var/www/freexduk เจ้าของไฟล์ www-data · wp-config.php สิทธิ์ 640
- กฎความปลอดภัยใน Nginx: ห้ามเข้าถึง wp-config.php, ไฟล์ซ่อน, ไฟล์สำรอง และห้ามรันไฟล์ .php ในโฟลเดอร์ uploads

3.4 DuckDNS และ HTTPS

- cron อัปเดต IP ไป DuckDNS ทุก 5 นาที (/etc/cron.d/duckdns)
- ขอใบรับรองด้วย acme.sh + dns_duckdns · --server letsencrypt (ค่าเริ่มต้นของ acme.sh คือ ZeroSSL) · redirect http > https · ต่ออายุอัตโนมัติผ่าน cron

ทำไมต้องใช้ DNS-01 แทน HTTP-01: แบบ HTTP-01 เซิร์ฟเวอร์ของ Let's Encrypt (อยู่ต่างประเทศ) ต้องเชื่อมต่อเข้ามาที่ port 80 ของเรา แต่ด่านที่ 2 บล็อก IP ต่างประเทศ จึงต่ออายุใบรับรองไม่ได้ ส่วน DNS-01 เราเป็นฝ่ายออกไปวาง TXT record ที่ DuckDNS เอง จึงไม่ติด firewall

ตารางที่ 6 ใบรับรอง HTTPS

รายการ	ค่า
ผู้ออก	Let's Encrypt (YE1)
ออกให้	freexduk.duckdns.org
หมดอายุ	8 ม.ค. 2570
Protocol	TLS 1.2 / TLS 1.3 · ทดสอบได้ TLSv1.3, Verify return code: 0 (ok)



ภาพที่ 4 หน้าเว็บ https://freexduk.duckdns.org พร้อมรูปกุญแจ และรายละเอียดใบรับรอง

4. ด่านที่ 2 — Firewall บล็อกการเชื่อมต่อจากต่างประเทศ

4.1 หลักการ

- ดาวน์โหลดช่วง IP ของประเทศไทยจาก ipdeny.com — IPv4 665 ช่วง และ IPv6 219 ช่วง — เก็บใน ipset (hash ค้นหาครั้งเดียว เร็วกว่าเขียน rule ทีละบรรทัด)
- INPUT policy = DROP แล้วเปิดเฉพาะที่จำเป็น (whitelist) · port 22/80/443 รับเฉพาะ IP ไทย · ที่เหลือทิ้งพร้อมบันทึก log GEOBLOCK-DROP
- อนุญาต 168.63.129.16 (แพลตฟอร์ม Azure) ตามข้อแนะนำของ Microsoft · IPv6 ใช้กฎแบบเดียวกัน
- cron อัปเดตรายการ IP ไทยทุกวันอาทิตย์ 04:30 · กฎอยู่รอดหลัง reboot (netfilter-persistent + ipset-persistent)
- auto-rollback 5 นาที ระหว่างเปิดใช้ ถ้าไม่ยืนยันภายในเวลา firewall คืนค่าเดิมเอง (ตั้ง policy เป็น ACCEPT ก่อนคืนกฎ — ถ้าใช้แค่ iptables -F policy DROP จะยังอยู่และล็อกตัวเองออก)
- fail2ban 3 jail: sshd · wordpress-login · nginx-botsearch (แบน 1 ชม. และนานขึ้นถ้าโดนซ้ำ)
- Azure NSG เปิดเฉพาะ 22, 80, 443

4.2 กฎ iptables และผลการทำงานจริง

```
$ sudo iptables -L INPUT -n -v --line-numbers
Chain INPUT (policy DROP)
1   58404  256M ACCEPT  lo
2   3254K 1097M ACCEPT  ctstate RELATED,ESTABLISHED
3    4193  310K DROP    ctstate INVALID
5       0     0 ACCEPT  168.63.129.16
8   13618  793K         tcp dpt:22 ctstate NEW recent: SET name: SSHBRUTE
10  13611  793K GEO-CHECK  tcp dpt:22
11   9353  493K GEO-CHECK  multiport dports 80,443
12      0     0 LOGDROP
$ sudo iptables -L GEO-CHECK -n -v
2152  113K ACCEPT   match-set th-net src    #มาจากไทย
20812 1173K LOGDROP                        #ต่างประเทศ ถูกทิ้ง
$ sudo ipset list -t
```

Name: th-net Number of entries: 665

Name: th-net6 Number of entries: 219

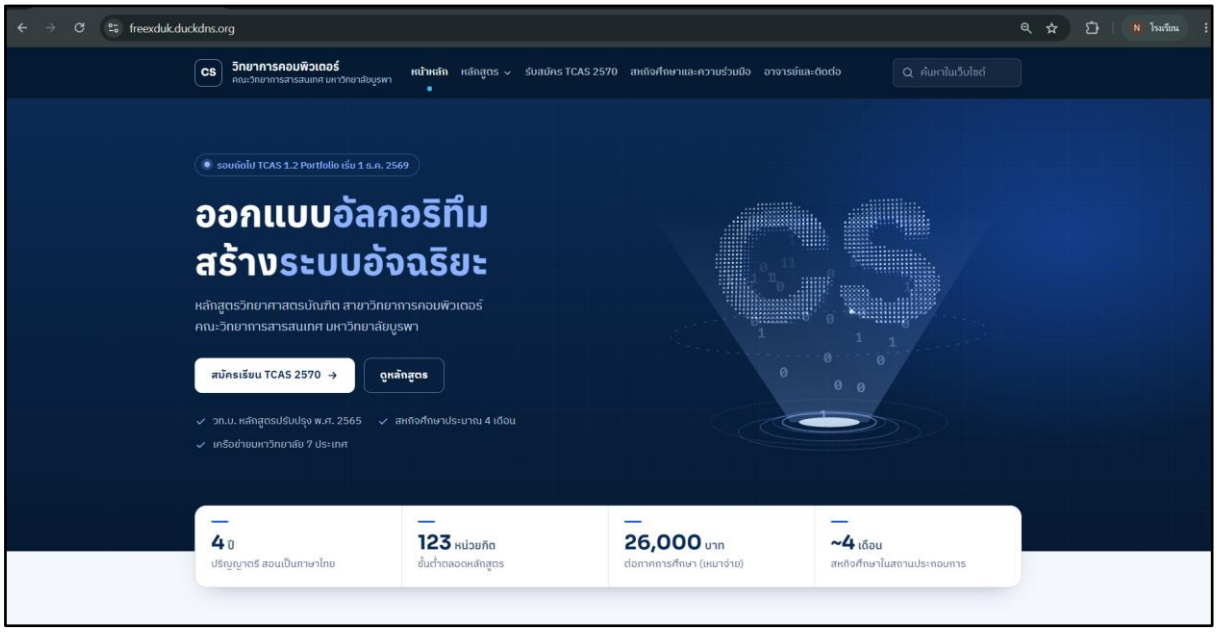
ผลการทำงานจริง: การเชื่อมต่อใหม่ที่ port 22/80/443 ถูกทิ้งเพราะไม่ได้มาจากไทย 20,812 ครั้ง เทียบกับที่รับจากไทย 2,152 ครั้ง — และมีความพยายามเชื่อมต่อ SSH ใหม่ถึง 13,611 ครั้ง ซึ่งเกือบทั้งหมดเป็นบอทสแกนจากต่างประเทศ (log การบล็อก 7 วันล่าสุด 4,771 บรรทัด ซึ่งถูกจำกัดไว้ 10 บรรทัด/นาที)

4.3 ผลการทดสอบ

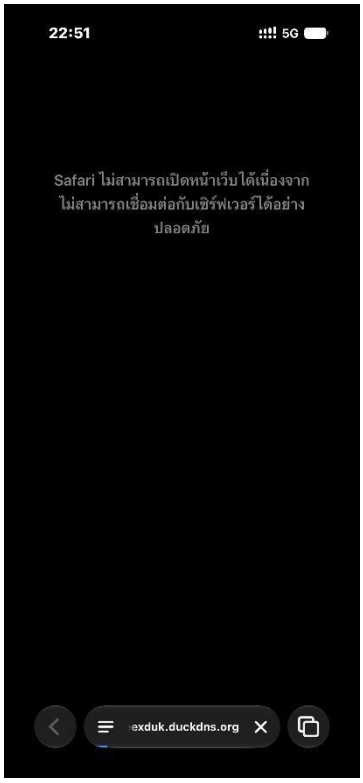
ตารางที่ 7 ผลทดสอบการเข้าถึงจากในและนอกประเทศ

ทดสอบจาก	ผล
เน็ตในประเทศไทย	เข้าได้ (HTTP 200)
check-host.net 40 เซิร์ฟเวอร์ (สหรัฐ ญี่ปุ่น สิงคโปร์ ฮ่องกง เยอรมนี อินเดีย ฯลฯ)	เข้าไม่ได้ 40/40 (Connection timed out)
VPN ต่างประเทศ	เข้าไม่ได้ (ดูภาพประกอบ)
หลัง reboot เครื่อง	กฎ, ipset, fail2ban กลับมาครบ

ข้อสังเกต: การทดสอบรอบแรกแบบ TCP มีเซิร์ฟเวอร์ยูเครน 1 จุดรายงานว่า "เข้าได้" ตรวจแล้วพบว่าใช้ Cloudflare WARP ซึ่งตอบรับการเชื่อมต่อแทนปลายทาง ขณะที่ log ฝั่งเราบันทึกว่าถูก DROP — จึงยืนยันซ้ำด้วยการทดสอบแบบ HTTP ซึ่งล้มเหลวทั้งหมด



ภาพที่ 5 เปิดเว็บจากเน็ตไทย — เข้าได้



ภาพที่ 6 เปิดเว็บผ่าน VPN ต่างประเทศ — This site can't be reached

Priority	Name	Port	Protocol	Source	Destination	Action
Inbound Security Rules						
300	HTTP	80	Tcp	Any	Any	Allow
320	HTTPS	443	Tcp	Any	Any	Allow
340	SSH	22	Tcp	Any	Any	Allow
65000	AllowVnetInBound	Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBou...	Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound	Any	Any	Any	Any	Deny

ภาพที่ 7 Azure NSG เปิดเฉพาะ port 22 / 80 / 443

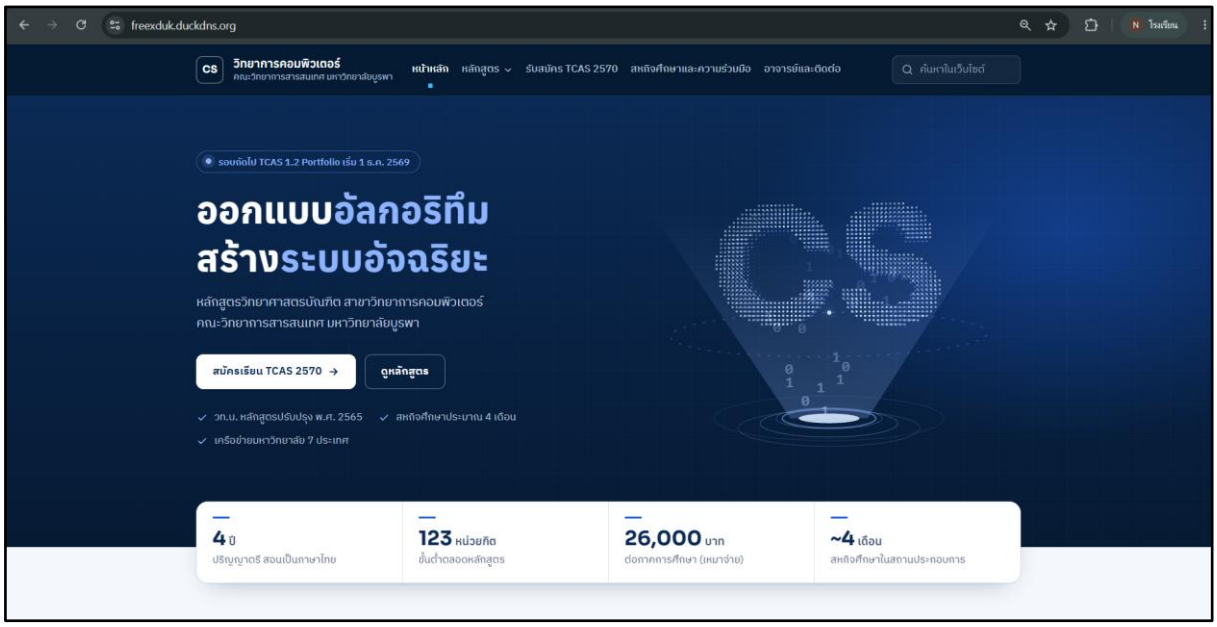
5. ด่านที่ 3 — เว็บไซต์แนะนำหลักสูตรวิทยาการคอมพิวเตอร์

5.1 โครงสร้างเว็บไซต์

กลุ่มเป้าหมาย: นักเรียนมัธยมปลายที่สนใจเรียนต่อ — จัดเนื้อหาเป็น 5 หน้าหลัก และใช้การเลื่อนไปยังหัวข้อย่อยภายในหน้า

ตารางที่ 8 หน้าเว็บและเนื้อหา

หน้า	URL	เนื้อหา
หน้าแรก	/	ภาพรวมหลักสูตร · ลิงก์ไปทุกส่วน
หลักสูตร	/curriculum/	เกี่ยวกับหลักสูตร (#cs-about) · โครงสร้าง (#cs-structure) · ผลลัพธ์การเรียนรู้ (#cs-plo) · เส้นทางการเรียน (#cs-path) · อาชีพหลังจบ (#cs-career) · ผลงาน/รางวัล (#cs-awards)
สหกิจศึกษา	/coop/	ชั่วโมงฝึกงาน (#cs-hours) · สถานประกอบการ (#cs-partners)
รับสมัคร	/admission/	คุณสมบัติ (#cs-req) · ลิงก์ TCAS / e-admission
อาจารย์และช่องทางติดต่อ	/contact/	ข้อมูลติดต่อ · ช่องทางโซเชียล



ภาพที่ 8 หน้าแรกของเว็บไซต์ (desktop)



ภาพที่ 9 หน้าเว็บบนมือถือ

5.2 Theme และ Plugin

ตารางที่ 9 Theme และ Plugin ที่ใช้

ประเภท	ชื่อ	หน้าที่
Theme	Kadence 1.5.2	เบา โหลดเร็ว รองรับ block editor
แคช	Cache Enabler	เก็บหน้าเว็บเป็น HTML (PHP ใช้เวลาจาก 0.043 > 0.001 วินาที)
บีบอัดรูป	EWWW Image Optimizer	บีบอัดรูปตอนอัปโหลด

ประเภท	ชื่อ	หน้าที่
ฟอร์มติดต่อ	Contact Form 7 + Flamingo	เก็บข้อความใน wp-admin (Azure บล็อก port 25 จึงไม่ส่งอีเมลตรง) · หน้าติดต่อที่ออกแบบใหม่ใช้ช่องทางติดต่อของคณะแทนฟอร์ม
ความปลอดภัย	Limit Login Attempts Reloaded	จำกัดการ login ผิด (คู่กับ fail2ban)
ความปลอดภัย	Two Factor	ยืนยันตัวตน 2 ขั้นตอนตอน login (เพิ่มภายหลัง หัวข้อ 7.4)

5.3 การเพิ่มความปลอดภัยของ WordPress

- ปิด XML-RPC 2 ชั้น: Nginx ตอบ 403 + mu-plugin disable-xmlrpc.php
- ชื่อผู้ใช้ไม่ใช่ admin · สมาชิกแต่ละคนมีบัญชีของตัวเอง
- กันการสืบรายชื่อผู้ใช้ (/wp-json/wp/v2/users, ?author=1) เฉพาะคนที่ไม่ได้ login ด้วย mu-plugin — คนนอกได้ 404 แต่ block editor ของทีมยังใช้งานได้
- ห้ามรันไฟล์ PHP ในโฟลเดอร์ uploads (ทดสอบด้วยไฟล์จริง ได้ 403 และไม่ถูกรัน) · ปิดการแก้ไฟล์ธีมผ่านหน้าเว็บ (DISALLOW_FILE_EDIT)
- สำรองฐานข้อมูลและไฟล์เว็บก่อนให้ทีมเริ่มแก้ (~/backups/)
- เสริมภายหลัง (หัวข้อ 7): ปิดการสืบชื่อผู้ใช้ผ่าน ?author= ลิงก์ผู้เขียน และ oEmbed ให้ครบ · ซ่อนเลขเวอร์ชัน · administrator เหลือ 1 คน + 2FA · Content-Security-Policy แบบ hash

6. Stage 2 — ยกระดับความปลอดภัยและประสิทธิภาพ

โจทย์: ปรับโครงสร้างให้ปลอดภัยหรือมีประสิทธิภาพสูงขึ้น เช่น reverse proxy, Cloudflare cache และนำ AI มาสแกน log ตามระยะเวลาเพื่อสร้าง dashboard ตรวจสอบการโจมตี

6.1 Reverse Proxy

แยก Nginx เป็น 2 ชั้น: หน้าบ้าน (รับ 443) ทำ TLS, rate limit, micro-cache แล้วส่งต่อไป origin ที่ฟังเฉพาะ 127.0.0.1:8080 ซึ่งรัน WordPress

ตารางที่ 10 การตั้งค่า reverse proxy

ความสามารถ	การตั้งค่า
Rate limit ทั่วไป	10 request/วินาที ต่อ IP (burst 100) — ตอบ 429 เมื่อเกิน
Rate limit หน้า login	10 ครั้ง/นาที ต่อ IP (burst 5)
Micro-cache	cache หน้าเว็บ 10 วินาที · header X-Cache-Status บอก HIT/MISS/BYPASS
ไม่ cache	คนที่ login · wp-admin · wp-login · wp-json · request ที่มี query string หรือไม่ใช่ GET/HEAD
IP จริงของผู้ใช้	ส่ง X-Forwarded-For → origin ใช้ real_ip (WordPress, fail2ban, Limit Login เห็น IP จริง)
ขนาดอัปโหลด	client_max_body_size 32m (ค่าเริ่มต้นของ Nginx คือ 1 MB)
ย้อนกลับ	10-reverse-proxy.sh --rollback คืน config เดิมในคำสั่งเดียว

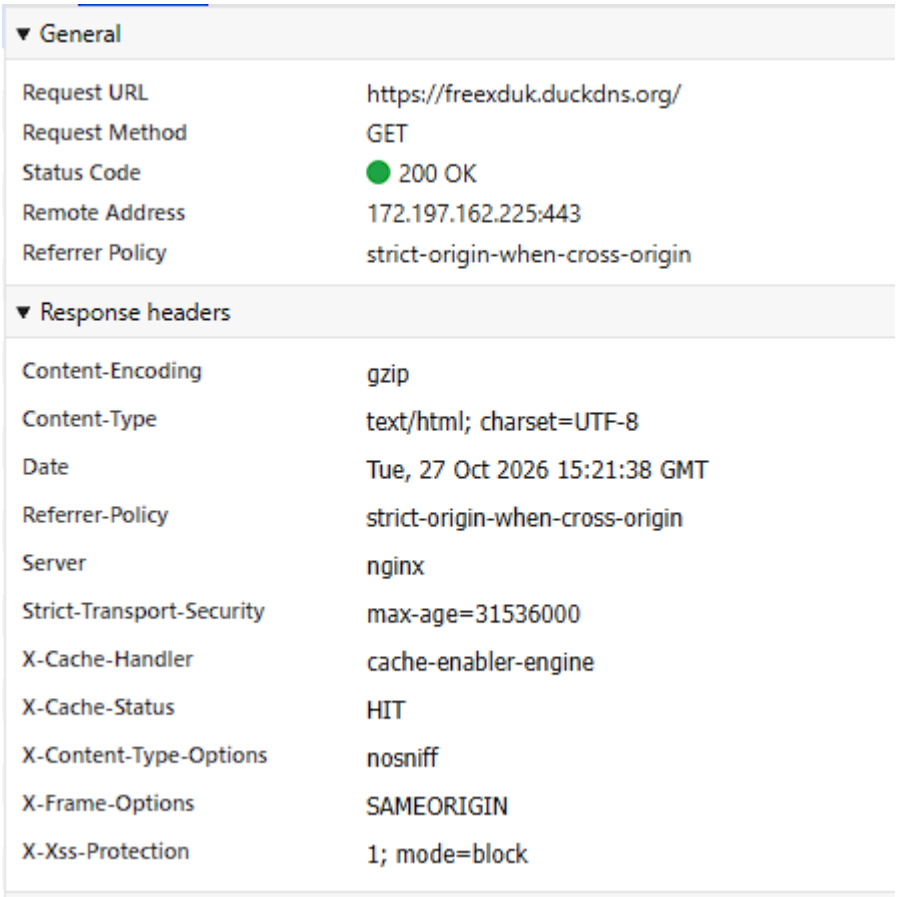
ตารางที่ 11 ผลทดสอบ reverse proxy

ทดสอบ	ผล
เปิดหน้าแรก 3 ครั้ง	X-Cache-Status: MISS → HIT → HIT
มี cookie ของคนที่ login	X-Cache-Status: BYPASS
GET /wp-login.php 20 ครั้งติดกัน	200 × 6 แล้ว 429 × 14
อัปโหลด 5 MB	ผ่าน (เดิมจะได้ 413)
IP ใน log ของ origin	IP จริงของผู้ใช้ (ไม่ใช่ 127.0.0.1)

ตารางที่ 12 ประสิทธิภาพก่อนและหลังทำ reverse proxy (วัดจากเครื่องในไทย วิธีเดียวกัน)

ตัวชี้วัด	ก่อน	หลัง	เปลี่ยนแปลง
TTFB หน้าแรก (p50)	0.293 s	0.156 s	เร็วขึ้น 47%
TTFB หน้าหลักสูตร (p50)	0.331 s	0.155 s	เร็วขึ้น 53%
TTFB หน้ารับสมัคร (p50)	0.237 s	0.154 s	เร็วขึ้น 35%
รับ request พร้อมกัน (N=200, c=10)	15.1 req/s	22.3 req/s	เพิ่มขึ้น 48%
p95 ตอนโหลดหนัก	1.013 s	0.469 s	ลดลง 54%

ข้อค้นพบ: ก่อนปรับปรุง PHP ใช้เวลาสร้างหน้าเพียง ~0.05 วินาที แต่ผู้ใช้รอ ~0.3 วินาที แสดงว่าเวลาส่วนใหญ่หมดไปกับเครือข่ายไทย > มาเลเซียและ TLS handshake — การ cache ที่หน้าบ้านจึงช่วยได้มากกว่าการเร่ง PHP



ภาพที่ 10 Response Headers ใน DevTools แสดง X-Cache-Status: HIT

6.2 AI วิเคราะห์ Log และ Security Dashboard

ระบบ logwatch ทำงานทุก 6 ชั่วโมงผ่าน systemd timer:

1. prepare.sh (บนเครื่อง) ดึงเฉพาะ log ที่ต้องใช้: Nginx access log · การบล็อกต่างประเทศ (GEOBLOCK-DROP) · SSH · fail2ban · สถานะระบบ ไปไว้ในโฟลเดอร์แยก
2. analyzer (Docker container) สรุปเป็นสถิติด้วยโค้ด — IP ที่ใช้งานมาก, ประเทศที่ถูกบล็อก (ฐานข้อมูล 241 ประเทศ), รูปแบบการโจมตี (SQL injection, path traversal, หาไฟล์ลับ ฯลฯ), login ล้มเหลว
3. ส่ง เฉพาะสรุป (~4,000 token ไม่ใช่ log ดิบ) ให้ Claude API วิเคราะห์ และบังคับผลเป็น JSON ตาม schema: ระดับภัย · เหตุการณ์ · หลักฐาน · คำแนะนำ · IP ที่ควรตรวจสอบ
4. dashboard (container) แสดงผลที่ https://freexduk.duckdns.org/security-dashboard/

ตารางที่ 13 มาตรการความปลอดภัยของระบบ AI และ dashboard

ความเสี่ยง	มาตรการ
Container มีสิทธิ์มากเกินไป	รันเป็น user nobody · filesystem read-only · ตัด capability ทั้งหมด · อ่าน log ได้อย่างเดียว
Docker แก้ firewall เอง	ตั้ง "iptables": false · ใช้ network ของ host · dashboard ฟังเฉพาะ 127.0.0.1 — กฎ iptables ก่อน/หลังติดตั้งเหมือนเดิมทุกบรรทัด
Prompt injection ผ่านข้อความใน log	แจ้งโมเดลว่าข้อความใน log เป็นข้อมูลที่เชื่อถือไม่ได้ · ใส่ไว้ในแท็ก <log_stats>
AI ตัดสินใจผิด	AI เสนอ IP ที่ควรตรวจสอบเท่านั้น ระบบไม่แบนอัตโนมัติ
XSS ผ่านข้อความใน log	dashboard ใส่ข้อความด้วย textContent เท่านั้น + Content-Security-Policy ห้ามสคริปต์ inline
คนนอกเข้าดู dashboard	geo-block > rate limit > HTTP Basic Auth
ข้อมูลส่วนบุคคล (PDPA)	ส่งเฉพาะสถิติสรุป · ซ่อน IP บางส่วนบน dashboard เป็นค่าเริ่มต้น
API key รั่ว	เก็บใน /etc/logwatch.env สิทธิ์ 600 · key ผูกกับ workspace · ตั้งวงเงินสูงสุด

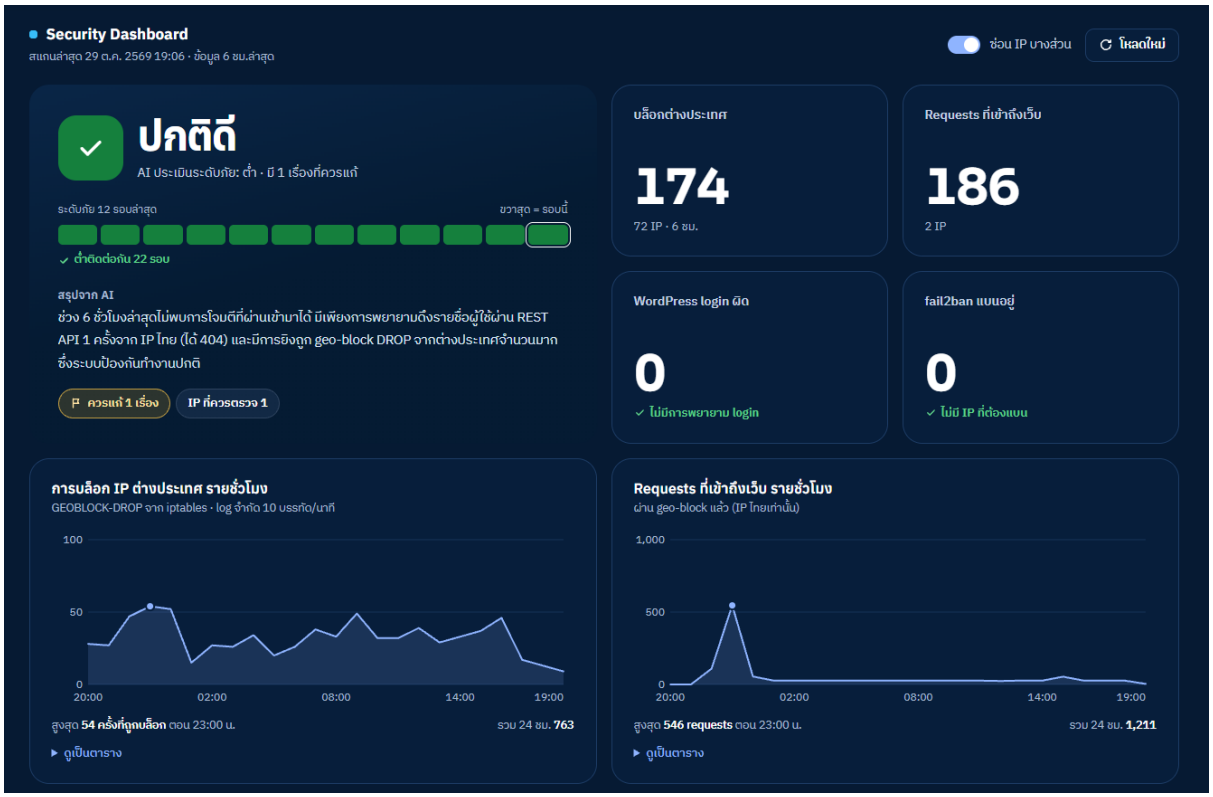
ตารางที่ 14 ค่าใช้จ่ายของ AI (วัดจริง)

รุ่น	token เข้า / ออก	ค่าใช้จ่าย/รอบ	เวลา
Claude Opus 5.5	3,914 / 3,055	$0.077	31.7 วินาที
Claude Sonnet 5.5 (ใช้งานจริง)	3,987 / 1,402	$0.022	13.3 วินาที

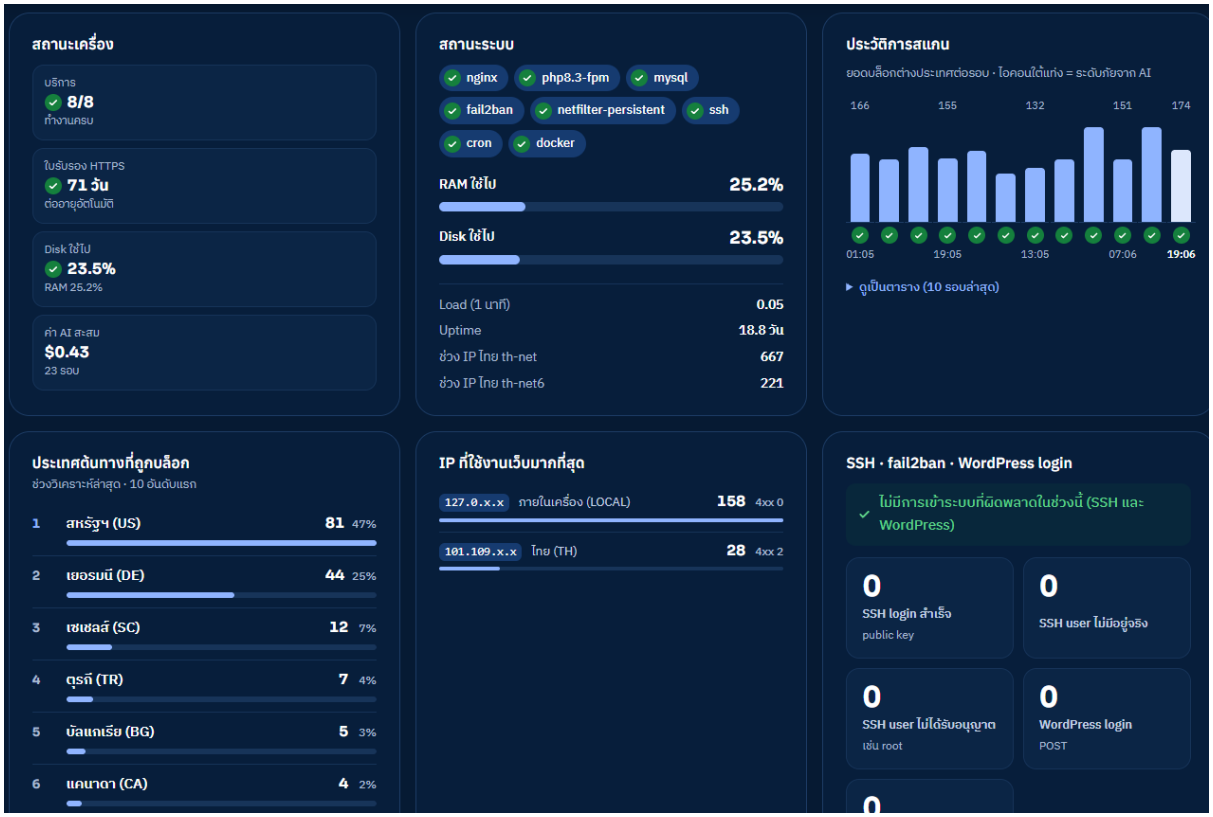
ผลลัพธ์ที่น่าสนใจ: ในการวิเคราะห์รอบแรก AI ตรวจพบปัญหาจริง 2 เรื่องเองโดยไม่มีใครบอก — (1) กฎ Nginx ที่ตั้งไว้กันการสืบรายชื่อผู้ใช้ไปบล็อก block editor ของทีมเอง 313 ครั้ง และ (2) IP ของเซิร์ฟเวอร์เองถูก geo-block 99 ครั้ง ซึ่งนำไปสู่การพบว่า WP-Cron ทำงานไม่ได้ ทั้งสองเรื่องได้รับการแก้ไขแล้ว (หัวข้อ 8)



ภาพที่ 11 หน้าต่างถามรหัสผ่านก่อนเข้า Security Dashboard



ภาพที่ 12 Security Dashboard: ระดับภัย ผลวิเคราะห์ของ AI



ภาพที่ 13 Security Dashboard: กราฟการบล็อกรายชั่วโมง

6.3 Cloudflare

Cloudflare ต้องทำหน้าที่เป็น nameserver ของโดเมน แต่ DuckDNS ไม่อนุญาตให้เปลี่ยน nameserver (ให้ตั้งได้แค่ A, AAAA, TXT) และ Cloudflare แบบฟรีรับเฉพาะโดเมนหลัก ไม่รับ subdomain ของผู้อื่นอย่าง *.duckdns.org จึงต้องใช้โดเมนที่จดเอง

แบบที่ออกแบบไว้ (docs/06-stage2-plan.md) — ใช้ "ทางเข้า 2 ทาง" ไปยังเว็บเดียวกัน:

ตารางที่ 15 แบบสถาปัตยกรรมเมื่อมีโดเมนจริง

	ทาง A: freexduk.duckdns.org	ทาง B: โดเมนจริงผ่าน Cloudflare
เส้นทาง	เข้าตรงมาที่ VM	Cloudflare edge > VM
บล็อกต่างประเทศ	iptables + ipset	Cloudflare WAF: ip.src.country ne "TH" > Block
Cache	micro-cache ที่ Nginx	CDN edge (มีเซิร์ฟเวอร์ในกรุงเทพฯ) + micro-cache
Origin	—	iptables รับ 80/443 เฉพาะ IP ของ Cloudflare · SSL Full (strict)
IP จริง	remote_addr	real_ip จาก CF-Connecting-IP (ถ้าไม่ตั้ง fail2ban จะแบน Cloudflare)

7. การตรวจและเสริมความปลอดภัยหลังติดตั้ง

หลังทำ Stage 2 เสร็จ คณะผู้จัดทำได้ตรวจความปลอดภัยของระบบอีกรอบทั้ง 2 ส่วน คือ โค้ดและไฟล์ตั้งค่าใน repository และ ระบบที่ทำงานอยู่จริงบนเซิร์ฟเวอร์ (ตรวจแบบอ่านอย่างเดียว ไม่ทดสอบโจมตีเครื่องจริง) พบจุดอ่อน 11 ข้อ แก้ไขแล้ว 10 ข้อ ทุกข้อสำรองไฟล์ก่อนแก้ ทดสอบหลังแก้ และบันทึกคำสั่งไว้ใน runbook.md หัวข้อ 2.4–2.9

7.1 ผลการตรวจความปลอดภัย

ตารางที่ 16 จุดอ่อนที่ตรวจพบและการแก้ไข

#	จุดอ่อน	ระดับ	การแก้ไข	สถานะ
1	ชื่อ login ของผู้ดูแลหลุดผ่าน /?author=N, ลิงก์ผู้เขียน และ oEmbed	กลาง	mu-plugin ปิดทุกช่องทางสำหรับคนที่ไม่ได้ login (หัวข้อ 7.2)	แก้แล้ว
2	administrator 8 บัญชี	กลาง	เหลือ 1 บัญชี อีก 7 บัญชีเป็น Editor + ติดตั้ง 2FA (หัวข้อ 7.4)	แก้แล้ว
3	ปลั๊กอินมีอัปเดตค้าง (Contact Form 7, EWWW)	กลาง	อัปเดตเป็น 6.2.3 / 8.9.0	แก้แล้ว
4	token ของ DuckDNS เห็นได้ในรายการโปรเซส (ps)	กลาง	ส่ง URL ให้ curl ทาง stdin (curl -K -)	แก้แล้ว
5	สคริปต์อัปเดตรายชื่อ IP ไทยไม่ตรวจความผิดปกติ	ต่ำ	เพิ่มตัวกรองรายการผิดปกติ (หัวข้อ 7.5)	แก้แล้ว
6	เลขเวอร์ชันหลุดผ่าน readme.html, license.txt, meta generator	ต่ำ	Nginx ตอบ 404 + mu-plugin ซ่อน generator	แก้แล้ว
7	sudo ไม่ต้องใส่รหัสผ่าน	ต่ำ	กำหนดทำตอนจบโครงงาน (ระหว่างนี้ต้องใช้สั่งงานอัตโนมัติ)	ตอนจบโครงงาน

#	จุดอ่อน	ระดับ	การแก้ไข	สถานะ
8	เว็บหลักไม่มี Content-Security-Policy / Permissions-Policy	ต่ำ	CSP แบบ hash + Permissions-Policy (หัวข้อ 7.3)	แก้แล้ว
9	ปลั๊กอินและธีมที่ไม่ได้ใช้	ต่ำ	ลบ Akismet, Hello Dolly, ธีม 2023/2024 (เก็บ 2025 ไว้สำรอง)	แก้แล้ว
10	ติดตั้ง acme.sh ด้วย curl | sh	ต่ำ	ทำครั้งเดียวจากเว็บทางการผ่าน HTTPS — ยอมรับความเสี่ยง	แก้แล้ว
11	CSP ยังอนุญาต unsafe-inline	ต่ำ	ใช้ hash ของสคริปต์แทน (หัวข้อ 7.3)	แก้แล้ว

ส่วนที่ตรวจแล้ว ผ่าน ได้แก่ เปิด port ภายนอกแค่ 22/80/443 · MySQL, origin และ dashboard ฟังเฉพาะ 127.0.0.1 · INPUT/FORWARD เป็น DROP ทั้ง IPv4 และ IPv6 · SSH ใช้ key เท่านั้นและปิด forwarding · ปิด TLS 1.0/1.1 · ไฟล์ลับมีสิทธิ์ 600 · container ไม่ใช่ root, read-only · โค้ด dashboard ไม่ใช้ innerHTML · เปิดอัปเดตความปลอดภัยอัตโนมัติ

7.2 ปิดการสืบชื่อผู้ใช้ให้ครบทุกช่องทาง

mu-plugin block-user-enum.php มีโค้ดกัน ?author= อยู่แล้ว แต่ทำงานที่ template_redirect ลำดับ (priority) เดียวกับฟังก์ชัน redirect_canonical ของ WordPress ซึ่งได้คิวก่อน ทำให้ WordPress พาไปที่ /author/<ชื่อ login>/ ก่อนถึงโค้ดของเรา ระหว่างแก้ยังพบอีก 3 ช่องทางที่หลุดชื่อเดียวกัน จึงแก้ทั้งหมดในไฟล์เดียว (เฉพาะคนที่ไม่ได้ login — ทีมยังใช้งานได้ปกติ)

ตารางที่ 17 ผลทดสอบการปิดช่องทางสืบชื่อผู้ใช้

ช่องทาง	ก่อนแก้	หลังแก้
/?author=1 ถึง 8	301 ไป /author/<ชื่อ login>/	301 ไปหน้าแรก (ย้ายโค้ดไป priority 1)
/author/<ชื่อ>/	เปิดได้	404
ลิงก์ผู้เขียนในหน้าข่าว	มีชื่อ login	ชี้ไปหน้าแรก
oEmbed author_url	มีชื่อ login	ตัดออก

ช่องทาง	ก่อนแก้	หลังแก้
ชื่อผู้เขียนที่ตรงกับ login (feed/หน้าข่าว)	แสดงชื่อ login	แสดงชื่อเว็บแทน
ทีมที่ login อยู่ (/wp/v2/users/me)	200	200 — block editor ใช้ได้ปกติ

7.3 Content-Security-Policy แบบ hash

CSP คือรายการที่เว็บบอกเบราว์เซอร์ว่ารันสคริปต์ได้จากที่ไหนบ้าง
ปัญหาคือหน้าเว็บมีสคริปต์ฝังในหน้า (inline) จำนวนมาก (จาก WordPress, ธีม Kadence และของทีม) ถ้าใช้ unsafe-inline สคริปต์ที่คนร้ายแอบฝังก็จะถูกรันด้วย คณะผู้จัดทำจึงคำนวณ sha256 ของสคริปต์ inline ทุกตัว ใน 12 หน้าสาธารณะ แล้วอนุญาตเฉพาะสคริปต์ที่ hash ตรง (สคริปต์ 11-csp-strict.sh ติดตั้งตัวสร้างนโยบาย csp-update-hashes.sh)
วิธีนี้ไม่ต้องแก้หน้าเว็บของทีมเลย

ตารางที่ 18 ขอบเขตของ CSP

ผู้เข้าชม	นโยบาย
คนทั่วไป (หน้าสาธารณะ)	Content-Security-Policy แบบ hash 16 ตัว — บังคับใช้
คนที่ login / wp-admin / wp-login	นโยบายเดิมแบบ Report-Only (กัน block editor พัง)
/security-dashboard/	CSP ของ container เอง (ห้ามสคริปต์ inline)

- เปิดโหมดทดสอบก่อน: รอบแรกพบสคริปต์ประเภท speculationrules ของ WordPress ที่ต้องมี hash ด้วย → แก้ตัวสร้าง (15 → 16 hash) รอบสองเปิด 10 หน้า ไม่มีแจ้งเตือน
- หลังบังคับใช้: ไม่มีสคริปต์ถูกบล็อก ไม่มี console error ภาพเคลื่อนไหวและเมนูทำงานปกติ
- ทดสอบว่ากันได้จริง: ฝังสคริปต์ inline ใหม่ผ่าน DevTools → ไม่ถูกรัน
- เพิ่ม Permissions-Policy (ปิดกล้อง ไมโครโฟน ตำแหน่ง การชำระเงิน USB)

ข้อควรรู้ในการดูแล: ถ้ามีการแก้หรือเพิ่มสคริปต์ในหน้าเว็บ ต้องรัน sudo csp-update-hashes.sh --enforce ใหม่ ไม่งั้นสคริปต์นั้นจะถูกบล็อก และห้ามตั้งให้รันอัตโนมัติ เพราะจะรับรองสคริปต์ที่ถูกฝังให้เอง

7.4 ลดสิทธิ์ผู้ดูแลและการยืนยันตัวตน 2 ขั้นตอน

- administrator เหลือ 1 บัญชี อีก 7 บัญชีเปลี่ยนเป็น Editor — แก้หน้า โพสต์ และรูปได้ แต่ติดตั้งปลั๊กอิน จัดการผู้ใช้ และเข้า Customize ของธีมไม่ได้ (หลัก least privilege: ถ้ารหัสของใครหลุด ความเสียหายจำกัด)
- ติดตั้งปลั๊กอิน Two Factor 0.17.0 (ของทีม WordPress) — สมาชิกเปิดใช้เองได้ในหน้าโปรไฟล์ด้วยแอป Authenticator

7.5 ตัวกรองรายชื่อ IP ไทย

สคริปต์อัปเดตรายชื่อ IP ไทยรายสัปดาห์เดิมเช็คแค่จำนวนขั้นต่ำ ถ้าแหล่งข้อมูล (ipdeny) ถูกแก้ให้มี 0.0.0.0/0 geo-block จะเปิดให้ทั้งโลกเข้าได้โดยไม่มีใครรู้ จึงเพิ่มฟังก์ชัน validate() ที่ปฏิเสธทั้งชุดและคงรายชื่อเดิมไว้ เมื่อพบช่วงกว้างกว่า /8 (IPv4) หรือ /16 (IPv6), IP ภายใน/พิเศษ หรือจำนวนรายการเพิ่มเกิน 2 เท่าหรือหดเกินครึ่ง (แก้หลังได้รับอนุญาต เพราะเกี่ยวกับ firewall — กฎ iptables ไม่เปลี่ยน)

ตารางที่ 19 ผลทดสอบตัวกรอง (`th-ipset-refresh.sh --selftest` — ไม่แตะ firewall จริง)

กรณีทดสอบ	ผลที่ต้องได้	ผล
รายการจริง IPv4 / IPv6	ผ่าน	PASS
แอบใส่ 0.0.0.0/0 / ::/0	ปฏิเสธ	PASS
แอบใส่ IP ภายใน 10.0.0.0/8	ปฏิเสธ	PASS
จำนวนพุ่ง 3 เท่า / หดเหลือ 1/3	ปฏิเสธ	PASS
รันจริง 1 รอบ	โหลด 667 / 221 ช่วงเท่าเดิม · กฎ iptables ไม่เปลี่ยน	hash ของกฎก่อน = หลัง

7.6 การรับมือช่องโหว่ฉุกเฉิน PHP2Shell

เดือนตุลาคม 2569 PHP ออกแพตช์ฉุกเฉินสำหรับช่องโหว่ PHP2Shell (CVE-2026-109618 และ CVE-2026-109619) ความรุนแรง 9.2/10 ที่ให้คนร้ายรันโค้ดบนเซิร์ฟเวอร์ได้โดยไม่ต้อง login และพบการโจมตีจริงแล้ว Ubuntu นำแพตช์มาใส่ใน 8.3.6 โดยไม่เปลี่ยนเลขเวอร์ชันหลัก (USN-8948-1)

ตารางที่ 20 การตรวจสอบ PHP2Shell บนเซิร์ฟเวอร์

วันที่	เหตุการณ์ / ผลตรวจ
21 ต.ค. 2569	PHP ประกาศแพตช์ฉุกเฉิน (8.3.36) · Ubuntu ออก USN-8948-1
22 ต.ค. 2569	unattended-upgrades ติดตั้ง 8.3.6-0ubuntu0.24.04.13 ให้เอง (changelog มี CVE-2026-109618_109619.patch)
27 ต.ค. 2569	PHP-FPM รีสตาร์ท — ใช้โค้ดที่แพตช์แล้ว
28 ต.ค. 2569	ตรวจยืนยัน: เวอร์ชันที่ติดตั้ง = เวอร์ชันล่าสุดที่มีให้ · CVE-2026-115560 (ยังไม่มีแพตช์) ไม่เข้าเงื่อนไข เพราะไม่มีโค้ดเปลี่ยน session.serialize_handler

ข้อสรุป: การเปิดอัปเดตความปลอดภัยอัตโนมัติไว้ตั้งแต่ติดตั้ง
ทำให้เซิร์ฟเวอร์ได้รับแพตช์ภายใน 1 วันหลังประกาศ โดยไม่ต้องมีคนเฝ้าระบบ

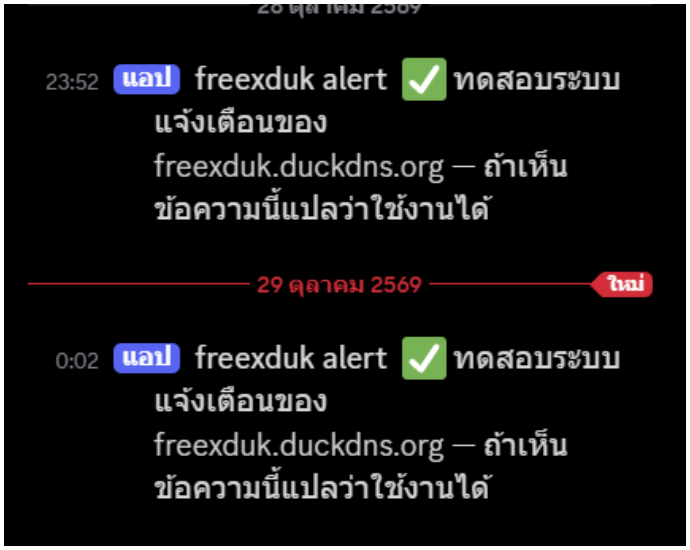
7.7 ระบบแจ้งเตือนทาง Discord

Security Dashboard แสดงผลเมื่อมีคนเปิดดูเท่านั้น จึงเพิ่มระบบแจ้งเตือน (12-alerts.sh) — สคริปต์ alert-check รันทุก 5 นาทีด้วย systemd timer แล้วส่งข้อความเข้า Discord webhook ของทีม

ตารางที่ 21 เงื่อนไขการแจ้งเตือน

ประเภท	เงื่อนไข
สถานะ (แจ้งครั้งแรก · เตือนซ้ำทุก 6 ชม. · แจ้งเมื่อกลับมาปกติ)	เว็บ/หน้า login ไม่ตอบ 200 · nginx, PHP, MySQL, fail2ban, Docker หรือ container dashboard หยุด · INPUT ไม่ใช่ DROP · รายชื่อ IP ไทยหาย · ใบรับรองเหลือ < 14 วัน · ดิสก์ > 90% · AI ไม่ได้สแกนเกิน 13 ชม.
เหตุการณ์ (แจ้งครั้งเดียว)	AI ประเมินระดับ medium ขึ้นไป · AI สแกนล้มเหลว · รายชื่อ IP ไทยที่ดาวน์โหลดมาผิดปกติ

- ข้อความจาก AI อ้างอิง log ที่คนร้ายควบคุมได้ จึง ซ่อน IP บางส่วน และ ปิดการ @mention ก่อนส่งออกนอกเครื่อง
- webhook เก็บใน /etc/alert.env สิทธิ์ 600 · ทดสอบด้วยข้อมูลจำลอง: ตรวจพบเว็บล่ม/บริการหยุด, ผล AI ถูกซ่อน IP, ไม่แจ้งซ้ำรอบเดิม · ทดสอบส่งเข้า Discord จริงสำเร็จ



ภาพที่ 14 ข้อความทดสอบระบบแจ้งเตือนในช่อง Discord ของทีม

7.8 ปัญหาที่พบระหว่างเสริมความปลอดภัย

ตารางที่ 22 ปัญหาที่พบในบทนี้และวิธีแก้

ปัญหา	สาเหตุ	วิธีแก้
แก้ CSP ของ dashboard แล้วไม่มีผล	container ผูก bind mount กับไฟล์ config ตัวเดิม (inode เก่า)	สร้าง container ใหม่ (--force-recreate)
ทดสอบ header ทันทีหลัง reload ได้ค่าเก่า	worker เดิมของ Nginx ยังตอบอยู่ชั่วขณะ	รอ 1–2 วินาทีแล้วทดสอบใหม่
หน้าข่าวยังมีลิงก์ /author/ หลังแก้	micro-cache ของ Nginx ยังเก็บหน้าเก่า	ล้าง cache ทั้ง Cache Enabler และ Nginx
ต่อ SSH ใหม่ไม่ได้ระหว่างทดสอบ	ต่อ SSH ถี่เกิน 10 ครั้ง/นาที → โดนกฎ SSHBRUTE ของเราเอง (ทำงานตามออกแบบ)	รวมคำสั่งไว้ใน session เดียว · ปลดเองใน ~1 นาที
CSP แจ้งเตือน inline speculation rules	<script type="speculationrules"> ต้องมี hash ด้วย	เพิ่มประเภทนี้ในตัวคำนวณ hash

8. ปัญหาที่พบและแนวทางแก้ไข

ตารางที่ 23 ปัญหาที่พบระหว่างดำเนินงาน

#	ปัญหา	สาเหตุ	วิธีแก้
1	สร้าง VM ที่ Southeast Asia / East Asia ไม่ได้	บัญชี Azure for Students ถูก policy จำกัด region	ตรวจด้วย az policy assignment list > เลือก Malaysia West
2	ตั้ง SSH hardening แล้วอาจไม่มีผล	sshd ใช้ค่าทีเจอก่อน ไฟล์ของ Azure (50-...) ถูกอ่านก่อนไฟล์ 99-...	ใช้ชื่อ 00-hardening.conf + comment ค่าที่ชน
3	Nginx config ไม่ผ่าน	http2 on; ต้องใช้ Nginx 1.25.1+ แต่ Ubuntu 24.04 มี 1.24	ใช้ listen 443 ssl http2;
4	OCSP stapling ใช้ไม่ได้	Let's Encrypt เลิกให้บริการ OCSP ปี 2025	เอา ssl_stapling ออก
5	acme.sh ออกใบรับรองของ ZeroSSL	ค่าเริ่มต้นของ acme.sh	ใส่ --server letsencrypt
6	ไฟล์ .php ใน uploads ยังรันได้	Nginx ใช้ regex location ข้อแรกที่ตรง และกฎ .php อยู่ก่อนกฎห้าม	ย้ายกฎความปลอดภัยไว้ก่อน > ทดสอบได้ 403
7	reboot แล้ว firewall จะหาย	ไม่ได้ติดตั้ง ipset-persistent	ติดตั้ง + ทดสอบ reboot จริง
8	คำสั่ง rollback แบบ iptables -F ล็อกตัวเองออก	flush แค่กฎ แต่ policy DROP ยังอยู่	ตั้ง policy ACCEPT ก่อนคืนกฎ
9	Serial Console login ไม่ได้	user ไม่มีรหัสผ่าน (สร้างแบบ key อย่างเดียว)	ตั้งรหัสผ่านไว้สำหรับ console เท่านั้น
10	แคชของ WordPress ไม่ทำงาน	ไม่มี WP_CACHE ใน wp-config	เพิ่ม WP_CACHE > PHP 0.043 > 0.001 วินาที

#	ปัญหา	สาเหตุ	วิธีแก้
11	block editor ของทีมถูกบล็อก 291 ครั้ง	กฎ Nginx บล็อก /wp-json/wp/v2/users ทุกคน รวม /users/me ที่ editor ใช้	ย้ายไปกันใน WordPress เฉพาะคนที่ไม่ได้ login
12	WP-Cron ทำงานไม่ได้ตั้งแต่เปิด firewall	เครื่องเรียกโดเมนตัวเอง > ออกนอกแล้ววนกลับด้วย IP Azure > โดน geo-block	/etc/hosts: 127.0.0.1 freexduk.duckdns.org
13	อัปโหลดไฟล์เกิน 1 MB ไม่ได้	ไม่ได้ตัง client_max_body_size (ค่าเริ่มต้น 1 MB)	ตัง 32m ให้ตรงกับ PHP
14	Docker จะข้าม geo-block	Docker เขียน iptables เองและ port ของ container ข้ามกฎ INPUT	ตั๋ง iptables: false + host network
15	ทดสอบจากยูเครน "เข้าได้" 1 จุด	Cloudflare WARP ตอบ TCP แทนปลายทาง (false positive)	ยืนยันด้วย HTTP test + log ฝั่ง server

9. สรุปและข้อเสนอแนะ

9.1 สรุป

- ติดตั้ง WordPress บน VPS ได้ครบตามโจทย์ทั้ง 3 ด่าน ใช้งานผ่าน HTTPS, SSH ใช้ key อย่างเดียว และเข้าถึงได้เฉพาะจากประเทศไทย
- ใช้หลักการป้องกันหลายชั้น (defense in depth): Azure NSG > iptables/ipset > fail2ban > rate limit > WordPress hardening > Limit Login Attempts
- Stage 2 ทำให้เว็บเร็วขึ้น 35–53% และมีระบบ AI เฝ้าระวังที่ตรวจพบปัญหาจริงของระบบได้
- ทุกขั้นตอนเขียนเป็นสคริปต์ (00a–12, 99) และบันทึกคำสั่งพร้อมผลลัพธ์ใน runbook — ติดตั้งซ้ำบนเครื่องใหม่ได้
- หลัง Stage 2 ได้ตรวจความปลอดภัยทั้งโค้ดและระบบจริง พบจุดอ่อน 11 ข้อ แก้แล้ว 10 ข้อ เพิ่ม CSP แบบ hash ลดสิทธิ์ผู้ดูแล + 2FA และระบบแจ้งเตือนทาง Discord · ยืนยันว่าแพตช์ช่องโหว่ฉุกเฉิน PHP2Shell ถูกติดตั้งอัตโนมัติภายใน 1 วันหลังประกาศ

9.2 สิ่งที่ได้เรียนรู้

- ทดสอบทุกการเปลี่ยนแปลงด้วยข้อมูลจริง — ปัญหาหลายข้อ (กฎ uploads, WP-Cron, ขนาดอัปโหลด) ดูจากไฟล์ config อย่างเดียวไม่เห็น
- เตรียมทางกลับก่อนแก้ระบบสำคัญเสมอ — auto-rollback, ไฟล์สำรอง, Serial Console
- ความปลอดภัยต้องไม่ขัดการใช้งาน — กฎที่เข้มเกินไปเคยบล็อกทีมเอง ต้องวัดผลกระทบหลังเปิดใช้

9.3 ข้อเสนอแนะสำหรับการพัฒนาต่อ

- จดโดเมนจริงและย้ายไป Cloudflare ตามแบบในหัวข้อ 6.3 แล้วปิดทางเข้าตรง (origin ซ่อนสมบูรณ์)
- เพิ่ม Redis object cache และตั้งระบบสำรองข้อมูลอัตโนมัติไปเก็บนอกเครื่อง
- บังคับใช้ 2FA กับผู้ดูแลทุกคน และเปลี่ยน CSP ของหน้า wp-admin จาก Report-Only เป็นบังคับใช้
- ให้ sudo ต้องใส่รหัสผ่าน (จุดอ่อนข้อเดียวที่ยังเปิดอยู่จากหัวข้อ 7.1)

ภาคผนวก — สคริปต์และไฟล์ในโครงงาน

ตารางที่ 24 สคริปต์ติดตั้ง (โฟลเดอร์ scripts/)

สคริปต์	หน้าที่
00a-update-swap.sh	อัปเดตระบบ + swap 2 GB
00b-create-admin-user.sh	สร้าง user + sudo + วาง public key ของสมาชิก
01-harden-ssh.sh	ปิด root / password · ใช้ key เท่านั้น (มี --rollback)
02-install-lemp.sh	Nginx + PHP-FPM + MySQL 8 + ซ่อน version
03-install-wordpress.sh	WordPress + database + กฎความปลอดภัยของ Nginx
04-duckdns.sh	อัปเดต DNS + cron ทุก 5 นาที
05-https-acme.sh	Let's Encrypt (DNS-01) + redirect https
06-firewall-th-only.sh	iptables + ipset IP ไทย + auto-rollback
07-fail2ban.sh	fail2ban: sshd · WordPress login · bot scan
08-site-content.sh	theme + plugin + หน้าเว็บต้นแบบ
09-logwatch.sh	ระบบ AI วิเคราะห์ log + dashboard (container)
10-reverse-proxy.sh	Nginx หน้าบ้าน: rate limit · micro-cache (มี --rollback)
11-csp-strict.sh	Content-Security-Policy แบบ hash ของสคริปต์ inline (โหมดทดสอบ / --enforce)
12-alerts.sh	ระบบแจ้งเตือนทาง Discord (systemd timer ทุก 5 นาที)
99-collect-evidence.sh	สร้างรายงานหลักฐาน version / SSH / HTTPS / firewall

ตารางที่ 25 เอกสารประกอบ

ไฟล์	เนื้อหา
runbook.md	คำสั่งและผลลัพธ์จริงทุกขั้นตอน
report-stage1-2.md	รายงานหลักฐานที่สร้างจากเครื่องจริง (sshd -T, iptables -L -n -v, ipset list -t)
docs/01-architecture.md	แผนภาพสถาปัตยกรรม

ไฟล์	เนื้อหา
docs/06-stage2-plan.md	แผน Stage 2 และแบบ Cloudflare
docs/stage2-perf-after-phase2.txt	ผลวัดประสิทธิภาพหลังทำ reverse proxy